Cloud IAM and Data Security Design

Deepika Agnihotri

University of Maryland Global Campus

Introduction to Cloud Computing & CLCS 605

Professor Anthony Ayodele

Abstract

This paper examines the migration of a healthcare organization's patient management system to a cloud environment while ensuring full compliance with the Health Insurance Portability and Accountability Act (HIPAA). The primary objective is to safeguard Protected Health Information (PHI) through the implementation of robust access controls, comprehensive data security measures, and effective auditing mechanisms. The study emphasizes the importance of aligning cloud architecture with HIPAA requirements to maintain confidentiality, integrity, and availability of sensitive patient data throughout the migration process.

1. **User Roles :**

Physician

Justification: chose physician because, in healthcare organization physician should have permission for patient's record because based on previous record physician can prescribe medication or give suggest. Physician should have read write permission to the assigned patients records

Nurse

Justification: selected nurse because of some process nurse also have to followup towards patient. So Needs limited clinical access than physicians with time-based escalation for on-call shifts.

Billing specialist:

Justification: selected Billing specialist for the handling insurance details and bill. So they Needs access to billing and insurance data only and should be restricted for clinical edit rights.

Medical Administrator:

justification: selected medical admin for scheduling and registration. So ability to view audit logs for compliance investigations.

IT Administrator:

Justification: Needs to manage infrastructure and securities like IAM and KMS rather than patients personal records. So the rule called least privilege applied here. In simple term they will get the access only what they exactly require for system management and it's security.

2. **Access Control Mechanisms :**

Attribute-Based Access Control (ABAC):

Justification: ABAC choose because it adds stronger and more flexible access control by checking factors like who is user, their relationship to the patient, location of logging in. This ensures only those with a true necessary can view patient information, helping meet HIPAA rules. For example: a nurse can view only the records of assigned patients and only when accessing the system from trusted hospital network.

Role-Based Access Control (RBAC):

Justification: selected RBAC for given health care scenario because moving to the cloud as it ensures only authorized staff, such as doctors or nurses, can access the patient information which are they require for their work. This supports HIPAA compliance by enforcing least-privilege access and preventing unauthorized exposure of Protected Health Information (PHI).

Multi-Factor Authentication (MFA):

Justification:Multi-Factor Authentication (MFA) provides an additional security layer to sensitive patient data, even if a password is compromised. It helps prevent unauthorized access and phishing attacks. It supports HIPAA compliance for protecting electronic patient information, and reduces the chances of costly data breaches.

3. **Data Protection Strategies :**

Data Encryption in Transit:

Justification: Data encryption in transit is essential for healthcare organizations moving their patient management system to the cloud because it protects sensitive patient information from hackers or unauthorized users. It ensures HIPAA compliance, prevents data breaches, and keeps health records secure as they travel between systems, devices, and networks. Encrypting data also helps reduce the risk of financial, legal, and operational problems if information is exposed.

Key Management Service (KMS):

Justification: KMS choose for the given healthcare organization to centrally manage encryption keys, ensuring that only authorized personnel(based on role will get access to the key) or systems can access patient data, both at rest and in transit. This prevents unauthorized access and helps maintain data privacy and compliance with regulations like HIPAA.

4. ***Monitoring and Audit :***

Cloud/Activity/Audit Logs:

Justification: This log records all the activities happening in cloud. Just like who logged in which file and at what time. So that if any unauthorized user try to access it will catch out easily. This also helps demonstrate compliance with HIPAA rules if the organization is ever audited

Intrusion Detection System (IDS):

Justification: IDS is important because it continuously monitors the system or network activity in cloud. So that it will indicate if any suspicious activity for cyber attack or security breach. So that it'll safe the patient's record before compromise.

References

1)AWS: https://docs.aws.amazon.com/IAM/latest/UserGuide/intro-structure.html

2)Azure: https://learn.microsoft.com/en-us/azure/role-based-access-control/rbac-and-directory-admin-roles

3)GCP: https://cloud.google.com/blog/products/gcp/getting-to-know-cloud-iam